

 **Problema a Solucionar:** El despliegue de plataformas de tipo e-commerce en entornos compartidos o VPS administrados (cPanel/WHM) suele introducir configuraciones débiles o por defecto donde los servicios de administración y correo apuntan directamente a la IP física del servidor lo que permite a un atacante descubrir la IP de origen a través de registros CNAMEs históricos o análisis de certificados. Esto puede ayudarlos a evadir por completo el WAF perimetral, perfilar la versión del backend e intentar ataques dirigidos a la lógica de la aplicación y a los paneles de gestión del hosting.

 **Metodología Aplicada:** Auditoría técnica intrusiva de caja negra tipo pentest controlado, enfocada en un único activo bajo el estándar PTES.

1. Desenmascaramiento de Servidor de Origen - Rastreo de registros CNAME del servicio de correo para saltar la protección perimetral de Cloudflare.
2. Análisis de Lógica de Aplicación (Parameter Tampering): Inyección de vectores de Path Traversal mediante la utilidad “curl” simulando la resolución local de hosts para evaluar la robustez del procesamiento de scripts centralizados “/filesystem”.
3. Auditoría de Paneles de Gestión: Intercepción y análisis de peticiones de autenticación en puertos de cPanel/WHM utilizando Burp Suite para evaluar la presencia de defensas contra la automatización.
4. Análisis Forense de Activos Digitales: Extracción de metadatos EXIF en archivos multimedia descargables para identificar software, rutas internas y autores.

 **Resultados Obtenidos (Caso de Estudio Muestra):** El objetivo evaluado (Aplicación web de comercio electrónico) alojada en un entorno VPS de Vodafone España al cual se le asigna un índice de riesgo de la infraestructura (IRI) con valor 55/100 (Riesgo moderado, reclasificado tras la aplicación de PoC).

Hallazgos Confirmados:

Elusión completa del WAF Cloudflare accediendo directamente a la IP pública del backend: Permite interactuar directamente con el activo, sin pasar por ningún tipo de mecanismo de protección contratado.

Fuga de información técnica crítica (Banner Grabbing): Permite perfilado tecnológico y búsqueda de vulnerabilidades específicas.

Revelación del uso de PHP 5.3.29, versión obsoleta y fuera de ciclo de vida (EOL): Tecnologías sin soporte oficial activo o parches de seguridad siempre presentan un riesgo inherente alto al no tener protección contra nuevos mecanismos de vulneración.

Exposición de puertos de administración cPanel/WHM (2082-2087) sin restricciones perimetrales por IP lo que permite que cualquier origen en Internet interactúe directamente con los servicios de administración.

Presencia de información sensible en los metadatos de las imágenes de los productos expuestos: Habilita la generación de perfiles de usuario o actividades de spear phishing.

Fortalezas:

Efectividad de controles compensatorios confirmadas mediante PoC, determinando que el vector de “Path Traversal” no es ejecutable (redirección 301): Aunque el paquete persiste, la aplicación funciona de manera segura sin exponer información confidencial.

Los paneles de cPanel cuentan con bloqueo automático tras 5 intentos fallidos, degradando el riesgo real del activo de Alto a Medio.

 **Herramientas utilizadas:** Burp Suite Professional (Intercepción y análisis de flujo de autenticación). curl (Inyección de parámetros y verificación de cabeceras HTTP). ExifTool (Análisis y extracción de metadatos de archivos). nmap (Fingerprinting y escaneo dirigido de puertos).

Lecciones aprendidas: Si no se tiene un control estricto de las configuraciones y la información de subdominios relacionados al activo se puede perder por completo la efectividad de la protección contratada permitiendo interacciones directas con el servidor de origen o depender completamente de las protecciones locales, las cuales suelen ser considerablemente menos efectivas.

Valor para la organización: En ocasiones, al contratar un servicio de protección se olvida de revisar o actualizar nuestro activo origen. Conocer las debilidades internas, así como las rutas que se pueden utilizar para evadir la protección externa permite tomar decisiones importantes sobre prioridad de actualización, configuración e inversión.